

The Data Protection Act 1998 (c. 29) (DPA) was an act of the Parliament of the United Kingdom designed to protect personal data stored on computers or in organized paper filing systems. It enacted provisions from the European Union (EU) Data Protection Directive 1995 on the protection, processing, and movement of personal data.

The 1998 act marked a significant change in how personal details were handled back in the UK. Before it, privacy laws mainly covered computer records, whereas this law was applied to both digital and physical files. It aimed to make sure that any group or company gathering data did it fairly, under ethical procedures, and kept user information safe and confidential as technology rapidly advanced.

Under the 1998 DPA, individuals had legal rights to control information about themselves. Most of the act did not apply to domestic or personal use, such as keeping a private address book. Anyone holding personal data for other purposes was legally obliged to comply with this Act, subject to some exemptions.

The act established eight crucial data protection principles to ensure that information was processed lawfully, kept accurate, stored securely, and utilised ethically.

The DPA 1998 was eventually superseded by the Data Protection Act 2018 (DPA 2018) on 23 May 2018, which extended the EU General Data Protection Regulation (GDPR), which came into effect just two days later, on 25 May 2018. The newer Act and GDPR strengthened privacy security and placed greater responsibility on companies handling personal data.

Background

The 1998 act replaced the Data Protection Act 1984 and the Access to Personal Files Act 1987. The act developed in response to growing concern in the 1990s about how easily personal data would be copied, altered, and shared due to rapid rise of computer systems. By that time, names, addresses, and financial records were often stored digitally instead of physical copies, increasing the risk of misuse and unauthorised access. In response, the EU introduced the

Data Protection Directive in 1995, which required all EU countries to pass strong data privacy laws.

The Privacy and Electronic Communications (EC Directive) Regulations 2003 later changed how organizations could contact people electronically. It introduced the idea of "positive consent," meaning companies needed individuals to agree before sending marketing emails or texts. However, companies could still send messages about "similar products or services" to existing customers unless they opted out.

The act also influenced other privacy laws, such as the Data Protection (Jersey) Law 2005, which was based on the UK's version. Around this time, the Information Commissioner's Office (ICO) was also created to enforce the act and handle complaints about data misuse. The ICO later became the UK's main authority for data privacy and protection.

Contents

Scope of protection

Section 1 of the Data Protection Act 1998 defined "personal data" as any information that could identify a living person. This included details such as a name, address, phone number, or email. The act applied to data stored electronically or in a "relevant filing system," which referred to organised paper records that could be easily searched for personal details.

The law also covered some paper documents if they were arranged in a way that allowed easy access to personal information, such as customer databases kept in folders. This meant businesses could not avoid compliance by claiming their data was not digital.

The Freedom of Information Act 2000 later worked alongside the DPA by allowing people to access data held by public bodies, while the *Durant v Financial Services Authority* case clarified how the term "personal data" should be used and interpreted. The *Durant* case ruled that not all mentions of a person's name count as personal data unless the information is genuinely

about the person or it affects or exposes their privacy in any way. This helped narrow down the definition and became one of the most cited cases in UK data protection history.

Data protection principles

Schedule 1 of the act listed eight protection principles. These principles required that data must be handled fairly, lawfully, and securely, and that it should not be used in ways that conflict with its original purpose.

Personal data shall be processed fairly and lawfully.

It shall be obtained only for valid and lawful purposes.

It shall be adequate, relevant, and not excessive.

It shall be accurate and kept up to date.

Information should not be kept for an unnecessarily prolonged period.

It shall be processed in accordance with the rights of individuals.

It shall be protected against unauthorised access, loss, or damage.

It shall not be transferred outside the European Economic Area without adequate protection.

These principles were the foundation of the UK's privacy law and continue to influence current rules under the Data Protection Act 2018 and GDPR. They made it clear that collecting personal data also came with the legal responsibility of protecting it. Many of these ideas were later simplified into six core principles under the GDPR, but the original structure in the 1998 Act helped set clear expectations for fairness and accountability.

Conditions relevant to the first principle

The first data protection principle stated that personal data should only be processed fairly and lawfully. To meet this standard, at least one of the several legal conditions had to apply, as listed in Schedule 2 of the act.

These conditions explained when it was acceptable for an organization to collect or use someone's information. An organization could only process data only if the conditions below were satisfied:

The person (known as the data subject) has consented ("given their permission") to the processing.

Processing is necessary for starting or continuing a contract.

The organization is required by law to process the data.

Processing is necessary to protect the person's vital interests (such as in a medical emergency).

It was required for official public duties.

It is necessary for the legitimate interests of the organization or another party, as long as it does not unfairly harm the individual's rights.

These six bases made it clear that not every use of data required direct consent. For example, a hospital could process patient records for treatment without written permissions, or a bank could store account data to fulfill its contract. The idea of "legitimate interest" was especially important, as it gave flexibility to organizations while still protecting individuals from unfair data handling.

Consent

The act required that individuals give consent before their personal data could be processed, unless another lawful basis applied. Consent was defined as a "freely given, specific, and informed indication" of agreement. Unlike modern privacy laws, the 1998 Act did not always require written consent. People could agree verbally or through actions that showed they accepted the use of their information, as long as it was clear they understood what they were agreeing to.

However, consent had to be appropriate to the person's age and capacity. If an organization planned to use someone's data even after their relationship ended, such as for future marketing, this needed to be stated clearly when the consent was obtained.

The act also created a higher standard for sensitive personal data, which included topics such as race, religion, health, and criminal history. In those cases, consent had to be explicit, often requiring written proof or clear affirmative action. Later updates, such as the Privacy and Electronic Communications Regulations (2003), built on this by making opt-in consent mandatory for most digital marketing. This change helped shape how modern companies handle emails, online cookies, and subscriptions.

Exceptions

The act stated that all processing of personal data was covered by its rules unless a specific exemption applied. These exemptions, listed in Part IV of the act, allowed certain activities to bypass some or all of the data protection principles when necessary.

Section 28 – National security. Any processing carried out for national security purposes was exempt from all eight data protection principles, as well as Part II (subject access rights), Part III (notification), and Part V (enforcement).

This exemption was used only in limited situations where applying the full rules could interfere with security investigations.

Section 29 – Crime and taxation. Personal data used to prevent or detect crime, catch offenders, or assess and collect taxes was exempt from the first data protection principle.

This meant law-enforcement agencies could request or use information without consent if it directly supported a criminal investigation or tax-related duty.

Section 36 – Domestic purposes. Personal data used solely for an individual's personal family, or household activities was exempt from all the data protection principles and the act's formal

notification rules.

Common examples included personal address books, home photo collections, or private communications that were not related to business or professional use.

These exemptions were designed to balance individual privacy with wider public interests. They ensured that the act did not block essential activities, such as national-security work or criminal investigations, while still protecting everyday personal data from unnecessary misuse.

Police and court powers

The act gave specific powers to police forces and courts when handling or requesting personal data.

Under Section 29, consent of the data subject was not required if information was processed to prevent or detect crime, to prosecute offenders, or to meet tax-collection duties.

This meant the police could obtain data such as phone records or financial details if it was relevant to an investigation. Courts could also order the disclosure of records when necessary for legal proceedings.

Section 35 allowed data to be shared if required by law or by a court order. This ensured that legal processes were not blocked by data-protection claims.

Even with these powers, public bodies were expected to protect confidentiality. Any data shared under these sections still had to be stored securely and used only for the stated purpose. The ICO later published guidance to help law-enforcement agencies apply these rules fairly.

Offences

The act created several civil and criminal offences for the misuse of data. These applied mainly

to organizations or individuals who handled information irresponsibly.

Section 21(1) made it an offence to process personal data without proper registration.

Section 21(2) penalised failures to follow notification requirements

Section 55 made it illegal to obtain or disclose personal data without authority, which covered hackers, impersonators, and employees who accessed files without permission.

Section 56 made it a criminal offence to force someone to make a subject-access request to reveal their criminal record during hiring or employment checks. This rule came into force on 10 March 2015.

Most of these offences were punishable by fines, but serious or repeated violations could lead to stronger legal action and damage an organization's reputation. Many cases ended with public warnings or court orders from the Information Commissioner.

These sections highlighted that the DPA was not just advisory; it had real legal weight. Organizations had to show they were taking data protection seriously or risk criminal liability. In practice, many companies struggled at first to understand their duties. Training programs and compliance audits later became common ways to avoid penalties.

Practical issues and complexity

The Data Protection Act 1998 was known for being quite complex, especially for smaller organizations that did not have legal or technical teams. Many people found the wording difficult to follow, and it was not always clear how the rules applied in day-to-day situations.

Early on, businesses and public bodies often misunderstood what counted as "personal data" or how long they were allowed to keep information. Some organizations even used the act as a reason to refuse sharing publicly available information, which showed how confusing the guidance could be at the time. The Information Commissioner's Office later published simplified explanations and examples to help organizations follow the rules correctly. These

guides encouraged clearer communication with the public and better record keeping practices.

Over time, training sessions and compliance checks became more common, especially in schools, hospitals, and local councils. These efforts helped raise awareness of the act, but they also showed how challenging it was for many groups to keep up with changing privacy expectations.

Definition of personal data

Under the act, personal data referred to information about a living person who could be identified from the data alone or when combined with other information. Examples included names, addresses, phone numbers, and financial details.

The act also recognized sensitive personal data, which required extra protection. This included information about a person's racial or ethnic background, political views, religious beliefs, trade-union membership, health records, sexual life, or criminal history: any information that was beyond just identifying a person.

The *Durant v Financial Services Authority* case later narrowed the meaning of personal data by stating that the information must be significantly connected to the individual, not just mention their name in passing. This decision influenced how organizations interpreted the law for several years.

These definitions became important as more data started being stored electronically. They helped establish the difference between general information and details that required stronger safeguards, especially in workplaces, healthcare, and government agencies.

Subject Access Requests and rights of individuals

One of the most important parts of the act was the set of rights it gave to individuals, known as data subjects. These rights allowed people to understand and control how their personal

information was being used.

Subject Access Requests (SARs):

Under Section 7, individuals could make a Subject Access Request to see the information an organization held about them. Companies usually had to respond within a set time and could only charge small fees in certain cases. SARs were commonly used to check for mistakes, understand how decisions were made, or confirm whether personal data had been shared with others. This became an important way for people to protect their privacy in the workplace, medical settings, and online services.

Other Rights Under the act

Individuals also had several additional rights, including:

The right to have incorrect data corrected (section 14).

The right to stop processing that could cause damage or distress (Section 10).

The right to prevent use of data for direct marketing (section 11).

The right to claim compensation if they suffered harm due to misuse of their data (Section 13).

These rights gave people more control over their information at a time when companies were collecting larger amounts of digital data. Many early complaints handled by the ICO involved inaccurate records, unwanted marketing messages, or unclear privacy notices. After the GDPR and Data Protection Act 2018 took effect, several of these rights were expanded or strengthened, but the foundations began with the DPA 1998.

Information Commissioner

The Information Commissioner's Office (ICO) was responsible for overseeing and enforcing the Data Protection Act 1998. The ICO provided guidance, answered public questions, and investigated complaints about how organizations handled personal data.

Many complaints involved issues such as inaccurate records, unwanted marketing, or unclear privacy notices. To help both the public and organizations, the ICO published practical guides and examples explaining how the act should be followed.

The ICO also maintained the public register of data controllers, which listed organizations that were legally required to notify how they processed data. Failure to register or follow basic obligations could result in warnings or fines.

As data use increased in schools, businesses, and healthcare settings, the ICO encouraged stronger security practices to reduce accidental loss or unauthorized access to personal information.

Legacy and Article 29 Working Party

The Article 29 Working Party was a European advisory group made up of representatives from each EU member state's data-protection authority. It issued opinions and guidance to help interpret the 1995 Data Protection Directive, including how rules about consent, fairness, and international data transfers should be applied. Its opinion helped shape how the DPA 1998 was understood in the UK, especially in areas where the act's wording was unclear. UK organizations often relied on these documents when deciding how to meet the law's requirements.

The Working Party later helped EU countries prepare for the General Data Protection Regulation (GDPR), which replaced the directive. When GDPR came into force in 2018, the DPA 1998 was repealed and replaced by the Data Protection Act 2018.

Although the 1998 act is no longer in force, it laid the foundation for modern UK privacy law and introduced many concepts that continue today.

See also

Computer Misuse Act 1990

Data privacy

Data Protection Act, 2012 (Ghana)

Data Protection Directive (EU)

Freedom of Information Act 2000

Gaskin v United Kingdom

General Data Protection Regulation – a 2016 EU regulation on data protection

List of UK government data losses

Privacy and Electronic Communications (EC Directive) Regulations 2003

Smith v Lloyds TSB Bank plc

Notes

References

External links

Text of the Data Protection Act 1998 as originally enacted or made within the United Kingdom, from [legislation.gov.uk](https://www.legislation.gov.uk).

Information Commissioner's Office

Council of Europe – ETS no. 108 – Convention for the Protection of Individuals with regard to Automatic Processing of Personal Data (1981) – basis for Data Protection Act 1984

Directive 95/46/EC of the European Parliament and of the Council of 24 October 1995 on the protection of individuals with regard to the processing of personal data and on the free movement of such data – basis for Data Protection Act 1998

Durant v Financial Services Authority [2003] EWCA Civ 1746

Data Protection Act 2018. UK Public General Acts. Vol. 2018 c. 12. 23 May 2018. From Data Protection Bill 2017-19 HL Bill [104]. Retrieved 26 April 2024.